VC Policy Engine — Implementation Plan

Nov 8, 2026 · @Suresh Unnikrishnan

Summary and how to use this plan

The plan delivers VC Policy Engine in six phases over 57 weeks, from 16 November 2026 to 19 December 2027. A bank or insurer pilot is in production by 10 July 2027, and the foundation application follows in January 2028. Each phase ends at a gate; the next phase starts only when the gate is met or a waiver is recorded.

Assumptions

- Start date 16 November 2026. Weeks are counted from that date (W1 = 16–22 Nov 2026).
- The core team in the Team and roles section is staffed by the end of W2.
- A licensed relying-party intermediary or QTSP partner supplies access certificates until we register in our own name (after G3).
- Standards stay as of November 2026: OpenID4VP 1.0, HAIP 1.0, SD-JWT VC draft-18, Token Status List draft. Spec changes are handled by the spec-tracking workstream.
- The design and the ADRs follow the Design & Architecture Document.

How to execute

1. Work the phases in order. Inside a phase, do the steps in number order; steps on the same line of work may run in parallel when the step says so.
2. Tick a step only when its **done when** condition is met and the evidence (PR, test run, document) is linked in a comment on that step.
3. At the end of each phase, hold a gate review with the product lead, tech lead and design-partner sponsor. Record pass, pass with waiver, or fail in the Plan governance section.
4. If a phase is late by more than two weeks, re-plan the following phase before starting it; never cut the gate checks.

Phases at a glance

Phase	Weeks	Goal	Gate
P0 Set-up and design partner	W1–W4	Partner signed, team and repo ready, ADR spikes done	G0

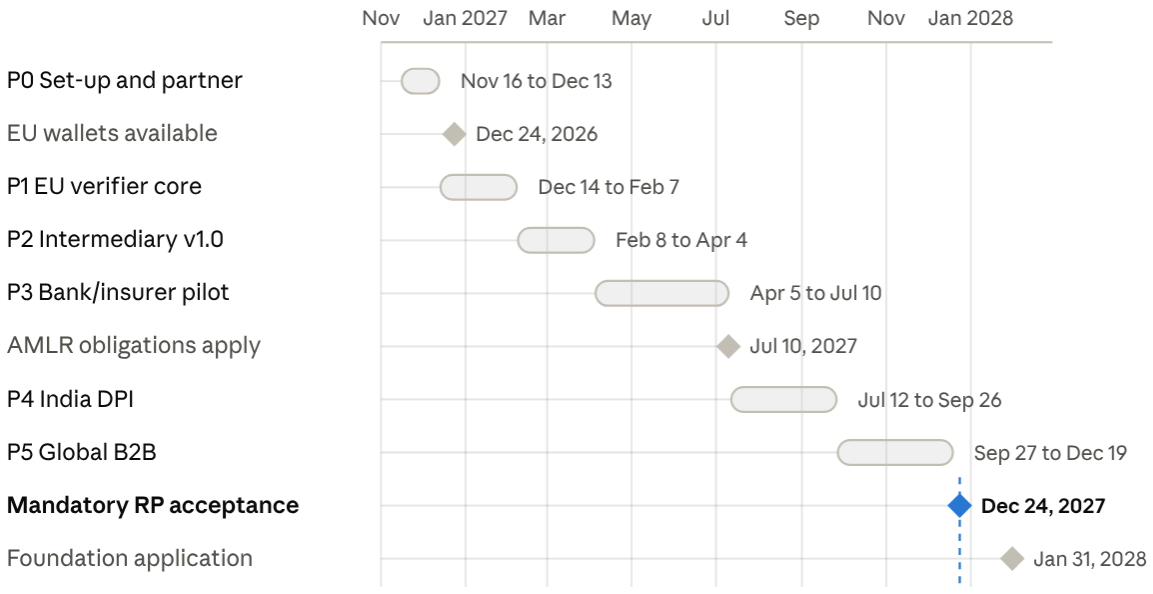
Phase	Weeks	Goal	Gate
P1 EU verifier core	W5–W12	SD-JWT VC + mdoc over OpenID4VP/HAIP with EU trust, status and policy	G1
P2 Intermediary service v1.0	W13–W20	Multi-tenant service, DC API, AuthZEN, Policy Studio, certification	G2
P3 Bank/insurer pilot	W21–W34	Sandbox, then production with the partner	G3
P4 India DPI	W35–W45	W3C VC 2.0, Inji, DigiLocker, DPDP mapping	G4
P5 Global B2B	W46–W57	vLEI, EU Business Wallet, UNTP, TRQP, OpenID Federation	G5

Roadmap

The EU path (P0–P3) comes first and is live before the AMLR date. India (P4) and B2B (P5) follow on the same core.

Six gated phases finish before EU wallet acceptance becomes mandatory

Implementation phases P0 to P5 (bars) and external deadlines (diamonds)



W1 starts 16 Nov 2026. Each phase ends at its gate (G0 to G5); the foundation date is a target.

implementation roadmap · P0–P5, W1–W57

The P3 pilot is the critical path. P0 starts the vendor-risk pack and sandbox applications so that P3 does not wait on paperwork.

Team and roles

The plan assumes a small core team of about eight people, plus part-time specialists. This is a proposal: step 0.2 confirms the numbers and the budget. Role codes are used as owners in every step below.

Code	Role	Allocation	Main phases
PL	Product lead (owns partner, gates, roadmap)	Full time	All
TL	Tech lead / architect (owns ADRs, design, code review)	Full time	All
PE	Protocol and crypto engineer (OpenID4VP, SD-JWT VC, mdoc, DC API)	Full time	P1–P2, P4
TE	Trust and status engineer (X.509, LoTL, status lists, TRQP, Federation)	Full time	P1–P2, P5
PO	Policy engineer (CEL, compiler, simulator, evidence)	Full time	P1–P2
FE	Frontend engineer (Policy Studio, console, demo wallet)	Full time	P1–P3
SRE	Platform and security engineer (cloud, KMS/HSM, CI, observability)	Full time	P0–P3
CO	Compliance and legal advisor (eIDAS, AMLR, DORA, DPDP)	Part time	P0, P2–P4
DR	Developer relations and community	Part time from P2, full time from P3	P2–P5
PS	Design-partner sponsor (at the bank or insurer)	External	P0, P3

Phase P0 — Set-up and design partner (W1–W4)

Goal: a bank or insurer signed as design partner, the team and repository ready, and the open technical choices settled by spikes.

Steps

- [ ] **0.1 Shortlist and approach design partners** (W1, PL). Pick three EU banks or insurers in countries with active EUDI sandboxes; send the Business Opportunity Report and a pilot proposal. *Done when:* meetings booked with at least two.
- [ ] **0.2 Confirm team and budget** (W1–W2, PL + TL). Staff the roles in Team and roles; estimate cost for P0–P3. *Done when:* budget approved and roles filled or contracted.
- [ ] **0.3 Create the open-source repository** (W1, TL + SRE). pnpm workspace, TypeScript strict, Apache-2.0 LICENSE, DCO check, CONTRIBUTING, SECURITY.md, CODE_OF_CONDUCT, public roadmap. *Done when:* CI runs lint, type-check and tests on an empty package set.
- [ ] **0.4 Set up CI/CD and supply-chain security** (W1–W2, SRE). GitHub Actions, changesets, dependency and secret scanning, SBOM, signed release provenance. *Done when:* a dummy package is published to a test registry with provenance.
- [ ] **0.5 Write core ports and domain types** (W2–W3, TL). `core` package: crypto, key, trust, status, storage and clock ports; typed errors; verified-vs-raw types. *Done when:* package-boundary tests prove `core` imports no framework or database.
- [ ] **0.6 Spike: OWF libraries** (W2–W3, PE). Wrap `openid4vc-ts`, `dcql-ts`, `sd-jwt-js` behind the ports; build one OpenID4VP request and verify one SD-JWT VC. *Done when:* ADR-002 accepted with findings.
- [ ] **0.7 Spike: mdoc library** (W2–W3, PE). Compare at least two mdoc verification options on correctness, maintenance and licence. *Done when:* ADR-004 decided.
- [ ] **0.8 Spike: CEL library** (W3, PO). Compare CEL implementations for TypeScript on safety (cost limits, no host access) and determinism. *Done when:* ADR-006 library decided.
- [ ] **0.9 Co-write the first policy with the partner** (W3–W4, PL + PO + CO + PS). Retail or insurance onboarding policy: required PID claims, rules, REVIEW reasons, retention. *Done when:* policy JSON and 20+ test cases agreed with the partner's compliance team.
- [ ] **0.10 Select an intermediary or QTSP partner** (W3–W4, PL + CO). For access certificates and, if needed, intermediary registration. *Done when:* partner chosen and sandbox certificates requested.
- [ ] **0.11 Start the DORA due-diligence pack** (W3–W4, CO + SRE). Sub-processors, incident process, exit plan, security controls. *Done when:* first draft shared with the partner's vendor-risk team.
- [ ] **0.12 Size the market bottom-up** (W4, PL). Count obliged relying parties in the first three target countries. *Done when:* figures added to the Business Opportunity Report.

- [ ] **0.13 Register for sandboxes and interop events** (W4, PL + PE). National EUDI sandbox (e.g. Germany) and the next OIDF interop event. *Done when:* applications submitted.

Deliverables

Repository and CI, `core` ports, ADR-002/004/006, agreed onboarding policy and test vectors, partner LOI, certificate partner, DORA pack v0.

Gate G0 (end of W4)

- Letter of intent signed by a bank or insurer.
- Onboarding policy and test vectors agreed with the partner.
- Team staffed; budget for P0–P3 approved.
- ADR-002, ADR-004 and ADR-006 accepted.

Phase P1 — EU verifier core (W5–W12)

Goal: an EU PID in SD-JWT VC or mdoc travels from the EU reference wallet through OpenID4VP/HAIP, trust, status and policy to an explained decision. W6–W7 fall over the year-end holidays, so plan one week of buffer.

Steps

- [ ] **1.1 Crypto and X.509 foundation** (W5–W6, PE + TE). `crypto` package: JOSE/COSE, algorithm allow-list, X.509 path validation with revocation hooks. *Done when:* RFC and NIST-style path test vectors pass.
- [ ] **1.2 SD-JWT VC verifier** (W5–W7, PE). Signature via `x5c` and issuer metadata, disclosures, KB-JWT, `vct` type metadata; accept `dc+sd-jwt` and `vc+sd-jwt`. *Done when:* the RFC 9901 example vector and 30+ negative cases (tampered, expired, wrong `aud`/nonce, bad disclosure) pass.
- [ ] **1.3 mdoc verifier** (W6–W9, PE). MSO signature and X.509 chain, value digests, validity, device authentication (session transcript for OpenID4VP and DC API). *Done when:* ISO 18013-5 sample vectors and negative cases pass.
- [ ] **1.4 OpenID4VP + HAIP request/response** (W7–W10, PE). JAR signed with the access-certificate key (`x509_hash`), DCQL from policy evidence, `direct_post.jwt` with ECDH-ES decryption, nonce/state store, replay rejection, `transaction_data`. *Done when:* OIDF OpenID4VP verifier tests pass locally.
- [ ] **1.5 EU trusted-list loader** (W5–W8, TE). Fetch and verify LoTL and national lists (ETSI TS 119 612), extract anchors by service type, cache with signature and fetch time, SSRF limits. *Done when:* the EU test LoTL loads and an anchor resolves a test PID issuer.

- [ ] **1.6 Claim-scope trust evaluator** (W8–W9, TE). Issuer authorisations by credential type and claim paths; versioned trust config. *Done when:* the test "valid signature, unauthorised issuer → never PASS" passes.
- [ ] **1.7 Status resolver** (W8–W10, TE). IETF Token Status List (JWT and CWT), mdoc MSO revocation, freshness limits, bounded cache. *Done when:* revoked gives FAIL, unavailable gives REVIEW, and stale beyond limit gives REVIEW.
- [ ] **1.8 Policy compiler and evaluator** (W5–W9, PO). JSON schema, typed bindings, restricted CEL with cost limits, PASS/FAIL/REVIEW aggregation, reason codes, fixed clock. *Done when:* the partner's 20+ test cases from step 0.9 pass deterministically.
- [ ] **1.9 Claim normaliser** (W9–W10, PO + PE). Map SD-JWT VC paths and mdoc data elements to the same typed bindings (e.g. `pid.birth_date`). *Done when:* the same policy gives the same result for the same person in both formats.
- [ ] **1.10 Evidence and decision records** (W10, PO). Canonical evidence digest; decision record with policy and trust versions; in-memory storage. *Done when:* a decision can be replayed from its record and fixtures.
- [ ] **1.11 SDK facade and demo apps** (W10–W11, TL + FE). `createVcPolicyEngine(...)`; demo issuer and demo wallet for local runs. *Done when:* `pnpm demo` runs the full flow on a laptop.
- [ ] **1.12 End-to-end with the EU reference wallet** (W11–W12, PE + TE). Run against the EU reference wallet and verifier test setup with sandbox certificates. *Done when:* PID in both formats yields an explained decision.
- [ ] **1.13 Conformance in CI** (W12, SRE + PE). Run the OIDF verifier suite (OpenID4VP 1.0 + HAIP) on every merge. *Done when:* the suite is green on `main`.
- [ ] **1.14 Threat-model review P1** (W12, TL + SRE). Review trust boundaries 2–5 against the design. *Done when:* findings logged and the critical ones fixed.

Deliverables

Packages `crypto`, `format-sd-jwt-vc`, `format-mdoc`, `openid4vp`, `trust`, `trust-eu-lotl`, `status`, `policy`, `policy-cel`, `evidence` and `sdk`, plus the demo apps. Release 0.1.0 (preview).

Gate G1 (end of W12)

- The EU reference wallet presents a PID in SD-JWT VC and in mdoc, and each yields an explained decision.
- The OIDF OpenID4VP + HAIP verifier tests pass in CI.
- The negative test matrix passes: tampered, expired, revoked, unauthorised issuer, replayed, wrong verifier, invalid binding, status unavailable.
- No open critical findings from the threat-model review.

Phase P2 — Intermediary service v1.0 (W13–W20)

Goal: a multi-tenant intermediary service, certified and pen-tested, that the partner can connect to in a sandbox.

Steps

- [ ] **2.1 PostgreSQL storage and tenancy** (W13–W14, TL + SRE). `storage-postgres` with migrations; `tenant_id` on every row; row-level security; tenant-bound tokens. *Done when:* cross-tenant access tests fail closed in CI.
- [ ] **2.2 Key provider and certificates** (W13–W15, SRE + TE). `keys-kms` (cloud KMS and PKCS#11); access-certificate key never exportable; per-tenant registration certificates with attribute checks against policies. *Done when:* a request is signed via KMS, and a policy asking for unregistered claims is rejected.
- [ ] **2.3 Fastify API service** (W13–W16, TL + PE). Tenant REST `/v1`, wallet endpoints, OpenAPI spec, idempotency, rate limits, size limits. *Done when:* OpenAPI contract tests pass.
- [ ] **2.4 AuthZEN decision endpoint** (W15–W16, PO). Map PASS/FAIL/REVIEW to AuthZEN responses with reason context. *Done when:* an AuthZEN client example gets correct results for all three outcomes.
- [ ] **2.5 Worker, outbox and webhooks** (W14–W16, SRE). Trusted-list and status refresh jobs; outbox; HMAC-signed webhooks with retries; retention jobs. *Done when:* killing the worker mid-delivery loses no event and duplicates none.
- [ ] **2.6 Digital Credentials API channel** (W14–W17, PE + FE). Server-built requests for OpenID4VP and ISO 18013-7 Annex C; browser helper; QR and same-device fallback. *Done when:* the flow works in Chrome (both protocols) and Safari (mdoc).
- [ ] **2.7 Policy Studio and console** (W14–W19, FE + PO). Visual rule builder with a CEL view; test cases; simulation; two-person publish; trust admin; decision explorer; REVIEW queue. *Done when:* the partner's compliance user publishes a policy version without engineering help.
- [ ] **2.8 Observability and runbooks** (W17–W18, SRE). Metrics, traces, alerts (list staleness, REVIEW surge, error rates), and the five runbooks from the design. *Done when:* each runbook has been rehearsed once.
- [ ] **2.9 OIDF self-certification** (W18–W19, PE). Run the OpenID4VP 1.0 + HAIP verifier profile and submit the results. *Done when:* the certification is published, or the submission is accepted for review.
- [ ] **2.10 External pen test** (W18–W20, SRE + TL). Scope: API, wallet endpoints, tenancy, parsers, console. *Done when:* no open critical or high findings.

- [ ] **2.11 Operator kit and docs** (W19–W20, DR + TL). Self-host guide, certificate and trusted-list operations guide, API reference, tutorials. *Done when:* an external developer runs the stack from the docs alone.
- [ ] **2.12 Release v1.0** (W20, TL). Semantic versioning, changelog, conformance matrix, signed artefacts. *Done when:* v1.0.0 is published to npm and the container registry.

Deliverables

v1.0.0 open core; managed intermediary service in staging (EU region); Policy Studio and console; OIDF certification; pen-test report; operator kit.

Gate G2 (end of W20)

- v1.0.0 released with a published conformance matrix.
- OIDF OpenID4VP + HAIP verifier self-certification published or accepted for review.
- External pen test has no open critical or high findings.
- The partner's staging tenant is set up with its policy and registration certificate.

Phase P3 — Bank/insurer pilot (W21–W34)

Goal: the design partner makes real onboarding decisions with the service before the AML Regulation applies on 10 July 2027, and agrees to scale.

Steps

- [ ] **3.1 Pilot plan and success criteria** (W21, PL + PS). Agree scope (product, channel, volume cap), success metrics (completion rate, REVIEW rate, decision time, manual effort saved) and the exit criteria. *Done when:* signed off by the partner sponsor.
- [ ] **3.2 Partner integration** (W21–W24, PE + PS). Connect the partner's onboarding app via REST or AuthZEN and webhooks; map REVIEW to their KYC queue. *Done when:* end-to-end tests pass in the partner's test environment.
- [ ] **3.3 Sandbox pilot** (W22–W26, PE + TE). Run in a national EUDI sandbox with sandbox wallets and PIDs. *Done when:* 100+ test journeys complete with expected outcomes.
- [ ] **3.4 Interop with national wallets** (W23–W28, PE). Test at least three national or certified wallets, plus Chrome and Safari DC API paths; join an OIDF interop event. *Done when:* the results are published in the interop report and open issues are tracked.
- [ ] **3.5 Vendor-risk and DORA approval** (W21–W28, CO + SRE). Complete the partner's vendor-risk review with the DORA pack, the pen test and the SOC 2 / ISO 27001 plan. *Done when:* the partner approves the service for production.

- [ ] **3.6 Intermediary registration via partner** (W24–W30, CO + PL). Register the pilot's relying-party use (directly or through the certificate partner) in the partner's member state; obtain production certificates. *Done when:* production access and registration certificates are issued.
- [ ] **3.7 Production readiness review** (W29–W30, TL + SRE). Capacity test, disaster recovery test, on-call rota, incident process with the partner. *Done when:* readiness checklist signed.
- [ ] **3.8 Production pilot** (W30–W34, PL + PS). Go live for the agreed product and volume; weekly reviews of REVIEW reasons and policy tuning through the Policy Studio. *Done when:* first production decisions recorded and the success metrics reported.
- [ ] **3.9 Case study and pricing** (W32–W34, PL). Agree a commercial contract and pricing from pilot data; publish a reference case if the partner agrees. *Done when:* contract to scale signed or decision recorded.
- [ ] **3.10 ISO 27001 gap assessment** (W30–W34, CO + SRE). *Done when:* a remediation plan is approved.

Deliverables

Partner live in production, interop report, DORA pack v1, production certificates, pilot results, commercial contract.

Gate G3 (end of W34)

- First production decisions made at the partner.
- Pilot success criteria met, or shortfalls with an agreed plan.
- The partner agrees to scale, or a second design partner is ready.
- Interop with at least three national wallets is documented.

Phase P4 — India DPI (W35–W45)

Goal: the same core decides on credentials from Indian DPI wallets (Inji, DigiLocker-issued VCs), with an Indian partner and DPDP Act compliance. The core is unchanged; only adapters are added.

Steps

- [ ] **4.1 India partner** (W35–W36, PL). Sign an Indian bank, NBFC or systems integrator working with MOSIP/Inji adopters. *Done when:* LOI signed and the first use case chosen (e.g. account opening or credit).

- [ ] **4.2 W3C VC 2.0 adapter** (W35–W39, PE). `format-w3c-vc`: JOSE/COSE securing and one Data Integrity suite (chosen in a short ADR), with pinned contexts and no remote JSON-LD loading. *Done when:* W3C test-suite vectors for the chosen suite pass.
- [ ] **4.3 Bitstring Status List** (W37–W38, TE). *Done when:* revoked and suspended cases map to FAIL and REVIEW as designed.
- [ ] **4.4 DID and Inji trust** (W37–W40, TE). `trust-did` for the DID methods Inji issuers use; anchor configuration per ecosystem. *Done when:* an Inji-issued test credential resolves to an authorised issuer.
- [ ] **4.5 Inji presentation and QR credentials** (W38–W42, PE). OpenID4VP flows with the Inji wallet; offline CWT/QR credentials (Claim 169) as a separate input path. *Done when:* an Inji wallet presentation and a QR credential each yield a decision.
- [ ] **4.6 DigiLocker-issued credentials** (W40–W42, PE + TE). Support the formats and trust anchors DigiLocker issuers use, where they are accessible through standard protocols. *Done when:* a DigiLocker-issued test credential verifies, or the gap is documented.
- [ ] **4.7 India region and DPDP mapping** (W39–W43, SRE + CO). Deploy an India-region tenant; map consent, purpose, retention and deletion to the DPDP Act. *Done when:* counsel has reviewed the mapping and the region passes readiness checks.
- [ ] **4.8 India pilot** (W43–W45, PL + partner). *Done when:* the first pilot decisions are recorded.

Gate G4 (end of W45)

- An Inji wallet presentation produces an explained decision.
- The DPDP Act mapping has been reviewed by counsel.
- No core-package changes were needed beyond adapters, or any change has an ADR.

Phase P5 — Global B2B (W46–W57)

Goal: the engine decides on organisations, not only people: broker, agent and supplier onboarding using vLEI, EU Business Wallet attestations and UNTP credentials. The first B2B pilot runs with the existing insurer or bank.

Steps

- [ ] **5.1 Pick the B2B use case with the partner** (W46, PL + PS). For example insurer broker/agent licence checks or supplier qualification. *Done when:* the use case, credentials and policy owner are agreed.

- [ ] **5.2 TRQP v2.0 adapter** (W46–W49, TE). Authorisation and recognition queries to trust registries, cached, behind `IssuerTrustResolver`. *Done when:* tests pass against a reference TRQP registry.
- [ ] **5.3 OpenID Federation adapter** (W47–W50, TE). Resolve and verify trust chains with OWF `openid-federation-ts`. *Done when:* a federated test issuer resolves.
- [ ] **5.4 Organisational credentials** (W48–W52, PE). vLEI (as reachable through standard formats or a bridge), EU Business Wallet attestations as specified at that time, UNTP Digital Identity Anchor and conformity credentials (W3C VC). *Done when:* each type verifies with test data, or the gap is documented.
- [ ] **5.5 B2B policy templates** (W50–W53, PO). Broker licence, supplier qualification (registration + insurance + conformity) and authorised-representative templates. *Done when:* templates ship with test cases in the open core.
- [ ] **5.6 Publish the policy schema as an open spec** (W52–W55, PO + DR). JSON schema, semantics, CEL profile and test vectors; propose to an appropriate standards group. *Done when:* the spec is published and an issue or proposal is filed with a standards body.
- [ ] **5.7 B2B pilot** (W53–W57, PL + PS). *Done when:* the first B2B pilot decisions are live.
- [ ] **5.8 Year-end readiness for mandatory acceptance** (W54–W57, SRE + PL). Capacity for EU tenants before 24 December 2027; customer communications. *Done when:* load test at the expected peak passes.

Gate G5 (end of W57)

- First B2B pilot live.
- TRQP and OpenID Federation adapters released.
- The policy spec is published.

After G5 — moving the core to a foundation

The open core moves to a neutral foundation once it has outside maintainers. The commercial service stays with us and keeps building on the open core.

- [ ] **6.1 Check readiness** (W57, TL + DR). At least two active maintainers from outside the company; governance file; stable v1.x releases. *Done when:* the criteria are met or a date is set to meet them.
- [ ] **6.2 Prepare the donation** (Jan 2028, PL + CO). Trademark and name check, contributor DCO history, licence audit (all Apache-2.0-compatible). *Done when:* legal review complete.
- [ ] **6.3 Apply to the OpenWallet Foundation** (by 31 Jan 2028, TL + PL). Lab-project proposal with roadmap and maintainers. *Done when:* the proposal is submitted.

- [ ] **6.4 Transfer and governance** (after acceptance, TL). Move the repositories, set up a technical steering group and keep our commercial repositories separate. *Done when:* the transfer is complete.

Cross-cutting workstreams

Five workstreams run through every phase. Each has one owner and a recurring check, so they never wait for a gate.

Workstream	Owner	Recurring activity	Cadence
Security	SRE	Threat-model review of new trust boundaries; dependency, secret and container scans; parser fuzzing	Each phase; scans on every build
Conformance and interop	PE	OIDF suite in CI; interop events; conformance-matrix update	Every merge; each release; each OIDF event
Spec tracking	TE	Watch OpenID DCP WG, IETF OAuth WG (SD-JWT VC, Token Status List), W3C FedID (DC API), EUDI ARF releases; raise ADRs for changes	Weekly review, monthly summary
Compliance	CO	eIDAS RP rules, AMLR, DORA, DPDP; DORA pack and ISO 27001 plan	Monthly; before each gate
Community and docs	DR	Release notes, tutorials, issue triage, contributor onboarding, talks	Every release; monthly community call from P2

Plan governance and risk tracking

The product lead owns this plan. Progress is tracked by ticking steps here; dates move only through a recorded gate decision.

- **Weekly:** team stand-up on the current phase's steps; blocked steps flagged with a comment.
- **Every two weeks:** demo to the design-partner sponsor (from P1).

- **Gate review:** product lead, tech lead and partner sponsor; outcome recorded in the gate log below.
- **Risks:** the risk register lives in the Business Opportunity Report. It is reviewed at every gate, and new risks are added there with an owner.

Gate log

Gate	Planned (end of week)	Outcome	Waivers / notes
G0	W4 (13 Dec 2026)		
G1	W12 (7 Feb 2027)		
G2	W20 (4 Apr 2027)		
G3	W34 (11 Jul 2027)		
G4	W45 (26 Sep 2027)		
G5	W57 (19 Dec 2027)		

Related documents: Business Opportunity Report · Design & Architecture Document · Opportunity, Industry & Interoperability Report